

BUSINESS ADMIN GUIDE

CPF BZA 매뉴얼

조직·사용자·권한·Data Scope·결재·위임을 업무 운영에 적용합니다.

Core Platform Framework · Source-aligned user documentation

주 독자 업무 관리자 · 결재 운영자 · 보안담당자

01 조직·사용자·권한 구조 적용	02 APPROVAL:WRITE/DECIDE 기반 결재 운영	03 위임·Masking·Audit·Backup/Upgrade 점검	
SOURCE	SOURCE REWORK	RUNTIME	RELEASE
4870b2073387 · 07_06	34/34 반영 · 신규 31 Action	0/13 live 실행	RELEASE_BLOCKED

07_06 Final QA 반영

● Inbox 결정 APPROVAL:DECIDE	● 상신·정책·위임 APPROVAL:WRITE
● retired 410 consumer 정리	● 인증 Browser matrix 는 미검증

PDF 는 공식 열람본, DOCX 는 동일 내용의 편집 원본입니다. 현재 Source 보완과 Runtime/QA 상태를 구분해 읽으십시오.

07_05 Source의 action-level permission을 기준으로 설명



그림 1. 이 문서의 핵심 업무 흐름

NAV	제목	NAV	제목	NAV	제목
01	BZA 도입 판단	05	Permission Simulation	09	Session·Masking·Audit·Export
02	조직	06	결재 Policy	10	Backup·Restore
03	사용자·Session	07	위임·대결	11	Upgrade·Rollback
04	Role·Permission·Data Scope·Masking	08	Attachment·Notification	12	현재 제품 검증 상태와 R6J 사용 경계

1. BZA 도입 판단

BZA를 선택하는 경우:

- 조직 기준일과 발령을 업무 권한에 사용.
- 사용자와 직원/조직을 연결.
- Role·Permission·Data Scope·Masking 필요.
- 결재 Policy·승인자 Snapshot·위임/대결 필요.
- 업무 Attachment/Notification/Audit/Export 정책 필요.

BZA가 하지 않는 일: 주문·계약·결제 같은 업무 최종 상태 소유.

2. 설치와 초기 관리자

1. Artifact/Checksum.
2. DB Vendor Pack.
3. Menu/Permission Seed.
4. 초기 관리자 계정.
5. MFA/Password/Session 정책.
6. Root 조직/대표 직원/사용자 연결.
7. 관리자 Role Simulation.
8. Backup/Restore/Login Smoke.
9. 초기 Credential 교체/Audit.

3. 조직

입력: code, name, parent, type, validFrom/To, status, expectedVersion, reason. 검증: cycle 방지, 기준일 중복 방지, 상위 유효기간, 폐기 영향 분석. 정상 판정: 기준일 조직 Path/Level 과 History 일치.

4. 직원·발령

- 직원 Profile 과 Login User 분리.
- 입사/이동/겸직/파견/휴직/퇴직을 기준으로 관리.

- 대표 Assignment 와 추가 Assignment 를 구분.
- 과거 Snapshot 을 현재 조직 변경으로 덮어쓰지 않는다.

5. 사용자·Session

사용자: loginId, employeeId, status, MFA, valid period, password policy. Session: issueAt, lastAccess, IP/device, expiry, revoke reason. 고위험 Role 변경/비밀번호 초기화/퇴직 시 Session 폐기 정책을 적용한다.

6. Role·Permission·Data Scope·Masking

세 층을 구분한다.

1. Menu 진입.
2. Action/API 실행.
3. Data Scope.

Masking/Unmask 는 별도 Permission 이며 원문 조회 자체를 감사한다.

Effective Permission 은 Allow/Deny 우선순위, Role 유효기간, 조직 기준일, Data Scope, Resource/Action, Masking 을 함께 계산한다.

7. Permission Simulation

입력: user, asOf, resource, action, target. 출력: allow/deny, matched role/policy, data scope, masking, reason. 실제 업무 API 의 Decision 과 Simulation 결과를 비교한다.

8. 결재 Policy

- Action/위험 조건.
- Policy Version.
- 단계/승인자 Role.
- 요청자-승인자 분리.
- 순차/병렬.
- 만료/Escalation.
- 위임/대결 범위.
- Snapshot/Checksum.

DRAFT → APPROVED → RETIRED 같은 Policy Lifecycle 을 사용하고 진행 중 문서는 생성 시점 Policy/Snapshot 을 보존한다.

9. 결재 Lifecycle

DRAFT → SUBMITTED → IN_REVIEW → APPROVED | REJECTED | WITHDRAWN | EXPIRED → EXECUTED

실행 전 Approval Snapshot 과 현재 Target Version/Hash 를 비교한다. Drift 가 있으면 재승인을 요구한다.

응답 유실은 결재 완료와 실제 업무 실행 결과를 별도로 대사한다.

10. 위임·대결

- 위임자/대리자.
- 기간.
- 조직/업무/Action 범위.
- 금지 권한.
- 자기 승인 방지.
- 결재 Snapshot 에 실제 Actor 와 Delegator 모두 기록.

11. Attachment·Notification

Attachment 는 Upload/Scan/Checksum/Quarantine/Download Permission/Expiry/Audit. Notification 은 Template/Channel/Recipient/Attempt/Retry/Cancel/DLQ 와 원문 민감정보 정책을 가진다.

12. Session·Masking·Audit·Export

Export 는 별도 Permission, Reason, Query Snapshot, Row Limit, Masking Policy, 만료 Token, Download Audit 를 사용한다.

13. 업무 Domain 연계

업무 Service 는 BZA 의 Effective Permission/Approval 결과를 **Consumer** 로 사용하지만 최종 업무 상태를 스스로 소유한다.

연계 시 고정할 것:

- Resource/Action Naming.

- Target Key.
- As-of Date.
- Required Permission.
- Data Scope Mapping.
- Masking Field.
- Approval Policy/Version.
- Audit Correlation ID.

14. 확장

고객 전용 조직 속성/Permission/Approval 조건을 추가할 때 기존 Public Contract 와 기준일/Version 의미를 유지한다. 내부 BZA Table 직접 의존 대신 공개 API/SPI 를 사용한다.

15. Backup·Restore

조직 History, Assignment, User/Role, Permission, Policy/Approval, Session/Audit/Attachment Metadata 의 일관성을 보존한다. Restore 뒤 Effective Permission Simulation 과 진행 중 Approval Snapshot 을 검증한다.

16. Upgrade·Rollback

Schema/API/Permission Seed/Frontend 를 함께 Versioning 한다. Mixed Version 에서 기존 Approval/Permission Decision 이 해석 가능한지 확인한다.

17. 운영 장애

- 잘못된 조직 기준일 → 과거/현재 Snapshot 비교.
- Permission 과다/부족 → Effective Simulation 과 실제 API Decision 대조.
- Approval stuck → participant/expiry/delegation/operation 확인.
- Session 과다 → revoke 정책과 Audit.
- Attachment scan 실패 → Quarantine.
- Export 응답 유실 → Export Job/Artifact 상태 조회.

18. 조직·권한·결재 통합 실습

Root 조직→부서→직원→사용자→Role→Permission→Data Scope→Simulation→Approval Policy→상신/승인→업무 실행→Audit 까지 수행한다. 중간에 조직 이동과 Approval Snapshot Drift 를 재현해 재승인 절차를 확인한다.

19. 완료 체크리스트

- 조직/직원/발령의 기준일이 있다.
- User/Employee/Session 이 분리된다.
- Role/Permission/Scope/Masking 이 분리된다.
- Simulation 으로 Effective 결과를 설명할 수 있다.
- Approval Snapshot/Version/Expiry 가 있다.
- 위임/대결/자기 승인 방지가 있다.
- Attachment/Notification/Audit/Export 가 있다.
- 업무 Domain 이 최종 상태 Owner 다.
- Backup/Restore/Upgrade/Rollback 이 있다.

20. 기준일·History 의 업무 적용

조직·발령·Role·Permission 을 현재값만 조회하지 않는다. 거래 발생시점, 결재 상신시점, 감사 조사시점에 맞는 asOf 기준으로 Effective 결과를 재현할 수 있어야 한다.

21. Approval 무결성

승인 요청은 Target ID 뿐 아니라 Action, Policy Version, Target Version/Hash, 주요 변경값, Requester, Expiry 를 Snapshot 으로 고정한다. 실행 시 동일 Snapshot 인지 비교한다.

22. 개인정보와 Retention

직원/사용자/첨부/감사/Export 데이터의 Retention, Archive, Legal Hold, 삭제 요청, Backup 예외를 분리한다. 삭제 후 복구된 Backup 에서 재삭제가 필요한지 절차를 정한다.

23. BZA 운영 화면 기준

현재 Router 는 인증 Session 을 복원한 뒤 각 Route 의 menuCode 를 hasBzaMenu(menuCode)로 검사한다. 인증되지 않은 사용자는 Dashboard 로그인 흐름으로 이동하고, Menu 권한이 없으면 /forbidden, 비활성 기능은 /feature-disabled, lazy-load 실패는 /lazy-load-failure, 미등록 URL 은 404 상태 화면으로 이동한다.

운영 화면은 아래 26 개 Route 를 정본으로 사용한다. expectedOperationIds 는 해당 화면에서 허용된 API/Operation 표면이며, Component 에 없는 Mutation 을 문서나 운영 절차에서 추가하지 않는다.

23.1 실제 BZA Route 26 개

ID	Path	화면	Menu	Group	목적	Expected Operation IDs
dashboard	/	대시보드	DASHBOARD	overview	업무 운영 현황	bzaSupportDashboard
organizations	/organizations	조직	ORGANIZATION	people	조직 계층	bzaBackofficeFindOrganizations, bzaBackofficeSaveOrganization, bzaBackofficeFindOrganizationsPage
employees	/employees	직원	EMPLOYEE	people	직원 Profile	bzaBackofficeFindEmployees, bzaBackofficeSaveEmployee, bzaBackofficeFindEmployeesPage, bzaBackofficeEmployeeRawContact
positions	/positions	직급	EMPLOYEE	people	직급 기준정보	bzaDirectoryFindPositions, bzaDirectorySavePosition, bzaDirectoryFindPositionsPage
jobTitles	/jobTitles	직책	EMPLOYEE	people	직책 기준정보	bzaDirectoryFindJobTitles, bzaDirectorySaveJobTitle, bzaDirectoryFindJobTitlesPage
assignments	/assignments	발령·겸직	EMPLOYEE	people	다중 소속·겸직·파견·대행	bzaDirectoryFindAssignments, bzaDirectorySaveAssignment, bzaDirectoryFindAssignmentsPage
organizationResponsibilities	/organizationResponsibilities	조직 책임	ORGANIZATION	people	조직장·대행·승인 Owner	bzaDirectoryFindResponsibilities, bzaDirectorySaveResponsibility, bzaDirectoryFindResponsibilitiesPage
users	/users	사용자	AUTHORIZATION	access	BZA 인증 사용자	bzaOperationFindAdminUsers, bzaOperationSaveAdminUser, bzaOperationFindAdminUsersPage
roles	/roles	역할	AUTHORIZATION	access	업무 역할	bzaOperationFindRoles, bzaOperationSaveRole, bzaOperationFindRolesPage
userRoles	/userRoles	사용자 Role	AUTHORIZATION	access	다중 Role 유효기간	bzaDirectoryFindUserRoles, bzaDirectorySaveUserRole, bzaDirectoryFindUserRolesPage
menus	/menus	메뉴	AUTHORIZATION	access	화면 메뉴 Registry	bzaOperationFindMenus, bzaOperationSaveMenu, bzaOperationFindMenusPage, bzaOperationDeleteMenu, bzaOperationFindMenuImpact

ID	Path	화면	Menu	Group	목적	Expected Operation IDs
permissions	/permissions	권한	AUTHORIZATION	access	화면·행위·API·Data Scope 권한	bzaOperationFindPermissions, bzaOperationSavePermission, bzaOperationFindPermissionsPage
permissionTools	/permissionTools	권한 분석	AUTHORIZATION	access	Role 비교와 권한 Simulation	bzaBackofficeFindEffectivePermissions, bzaSupportCompareRolePermissions, bzaSupportSimulatePermission
approvalInbox	/approvalInbox	결재 처리	APPROVAL	approval	Snapshot 참여자 Inbox	bzaApprovalInbox, bzaBackofficeFindApprovals, bzaBackofficeCreateApproval, bzaBackofficeFindApproval, bzaBackofficeActApproval
approvalSubmissions	/approvalSubmissions	결재 상신	APPROVAL	approval	정책 기반 맥등 상신	bzaApprovalSubmissions, bzaApprovalPolicySubmit, bzaApprovalExpireDue, bzaApprovalSubmissionDetail, bzaApprovalCancel, bzaApprovalResubmit, bzaApprovalWithdraw, bzaApprovalParticipantDecision
approvalPolicies	/approvalPolicies	결재 정책	APPROVAL	approval	Versioned Policy/ALL·ANY·N_OF_M	bzaApprovalPolicies, bzaApprovalPolicySave, bzaApprovalPolicyDetail
approvalSimulation	/approvalSimulation	경로 Simulation	APPROVAL	approval	조직/Role/위임 사전 해석	bzaApprovalPolicySimulate
approvalDelegations	/approvalDelegations	결재 위임	APPROVAL	approval	유효기간 위임·대결	bzaApprovalDelegations, bzaApprovalDelegationSave
sessions	/sessions	내 세션	AUTHORIZATION	support	Refresh session 관리	bzaAuthSessions, bzaAuthRevokeSession
audits	/audits	업무 감사	AUDIT	support	Immutable 업무 감사	bzaBusinessAuditVerify, bzaBackofficeFindBusinessAudits
notifications	/notifications	알림	SETTING	support	업무 알림	bzaSupportFindNotifications, bzaSupportCreateNotification, bzaSupportReadAllNotifications, bzaSupportReadNotification
attachments	/attachments	첨부파일	ATTACHMENT	support	첨부 업로드·검증	bzaSupportFindAttachments, bzaSupportUploadAttachment, bzaSupportDownloadAttachment, bzaSupportRecheckAttachment, bzaSupportUpdateAttachmentSecurity
savedSearches	/savedSearches	저장 검색	SETTING	support	사용자 검색 조건	bzaSupportFindSavedSearches, bzaSupportSaveSavedSearch, bzaSupportDisableSavedSearch
settings	/settings	업무 설정	SETTING	support	BZA 업무 설정	bzaOperationFindSettings
downloads	/downloads	다운로드 정책	SETTING	support	다운로드 정책	bzaOperationFindDownloadPolicies
downloadAudits	/downloadAudits	다운로드 감사	AUDIT	support	다운로드 감사	bzaSupportFindDownloadAudits

23.2 화면 운영 공통 규칙

1. 진입 전 인증 Session 과 Menu 권한을 확인한다.
2. 목록/상세 화면은 기준일·Data Scope·Masking 을 먼저 확인한다.
3. Save/Create/Act/Delete/Revoke/Upload/Download Operation 이 있는 화면만 해당 Mutation 절차를 제공한다.

4. 변경 시 expected version/idempotency/reason/approval 계약이 API 에 있으면 반드시 함께 전달한다.
5. 409 는 최신 Snapshot 재조회, Timeout/응답 유실은 operation/status 대사, 부분 반영은 대상별 reconcile 로 처리한다.
6. 원문·Raw Contact·Attachment·Download·Audit 는 별도 Permission/Masking/Reason/다운로드 감사를 확인한다.

23.3 Source 검수 예 — 조직 화면

OrganizationsPage.vue 는 조직명·코드 검색, 중지 조직 포함=true, 고아/순환 조직 탐지, 조직 코드/명/상위/유형/사용 여부/하위 수 상세를 제공한다. 이 화면 Component 에는 Save Button 이 없으므로 Route Registry 에 bzaBackofficeSaveOrganization Operation 이 있더라도 **현재 조직도 Component 에서 직접 저장한다고 쓰지 않는다**. 화면 Capability 와 API Registry 를 같은 것으로 오인하지 않는다.

24. BZA 제품과 Reference 경계

cpf-biz-admin 은 조직·직원·사용자·권한·결재를 제공하는 제품/확장 Surface 다. 제품 화면과 API 를 Generic EDU Handler 로 다시 구현한 수량은 품질 근거가 아니다. BZA 기능은 실제 Backend·Frontend·OpenAPI·SQL·Test 와 이 매뉴얼에서 검증하고, EDU 는 고객 업무가 Public Integration/Extension 계약을 소비하는 경우에만 사용한다.

BZA 제품 기능은 BZA Source/API/Frontend/SQL/Test 에서 검증하며 EDU 수량으로 완료를 판정하지 않는다. 07_05 Approval UI 는 결정 작업을 APPROVAL:DECIDE, 상신·철회·취소·재상신·기한만료·정책·위임 변경을 APPROVAL:WRITE 로 통제한다.

25. 조직도 운영 - 현재 Source 기준

현재 OrganizationsPage.vue 는 전체 깊이 조직 Tree 를 읽고 편집한다.

항목	실제 계약
조회	/api/bza/backoffice/organizations?limit=5000
검색	조직명·조직코드 문자열 검색
기본값	중지 조직 포함=true
구조 검증	Parent 가 없는 고아 조직과 순환 조직을 별도 Issue 로 표시
상세	조직코드, 상위 조직, 하위 조직 수
수정 입력	조직명, 상위 조직 코드, 조직 유형, 정렬 순서, 사용 여부, 변경 사유
조직 유형 기본값	DEPARTMENT
권한	ORGANIZATION / WRITE
동시성	Source 의 현재 Row Version 을 expectedVersion 으로 전달

항목	실제 계약
감사	변경 사유 필수

저장 후에는 목록을 다시 조회해 같은 조직코드의 최신 Row 를 선택하고 Version 과 계층을 확인한다. 409 가 발생하면 최신 조직 상태를 다시 읽고 Parent 변경과 조직명 변경을 재판단한다. 고아/순환 경고가 남은 상태를 정상 계층으로 간주하지 않는다.

26. 업무 알림 운영 - 현재 Source 기준

현재 NotificationsPage.vue 는 개인 알림 조회, 단건/전체 읽음, 업무 알림 등록과 업무 Reference 이동을 제공한다.

- 초기 조회는 unreadOnly=true, limit=100 이다.
- 단건 읽음과 전체 읽음, 업무 알림 등록은 SETTING / WRITE 권한을 요구한다.
- 등록 입력은 수신자 Login ID, 유형(기본 BUSINESS), 제목, 내용, 선택 referenceType/referenceld, 등록 사유다.
- 수신자·제목·내용·등록 사유가 비어 있으면 등록하지 않는다.
- referenceType=APPROVAL 이고 Reference ID 가 있으면 Approval Inbox 를 approvalId Query 로 연다.
- 목록에서는 생성시각, 유형, 제목, 내용, 읽음 상태를 확인한다.

알림 생성 응답이 유실된 경우 동일 메시지를 반복 생성하기 전에 Server 목록/업무 Reference 상태를 확인한다. 결재 알림은 알림의 읽음 여부가 결재 상태를 변경하지 않는다는 경계를 유지한다.

27. 승인 결과의 고객 업무 반영

고객 업무에 BZA 승인 결과를 적용할 때에는 approvalId, businessOperationId, approvalPolicyId, 대상 Version 을 함께 기록한다. APPROVED 는 업무 반영 성공과 동일하지 않다. Owner 적용이 진행 중이거나 응답이 유실되면 결과를 UNKNOWN_RESULT 로 분리하고 Owner 원장을 대사한다.

- 승인 Snapshot 과 실제 Owner 대상 Version 이 달라지면 적용을 중단하고 재승인을 판단한다.
- Callback 또는 사용자 재시도로 같은 업무 Command 가 중복되지 않도록 Operation/Idempotency 계약을 사용한다.
- 일부 대상만 반영되면 성공 대상을 보존하고 나머지를 Reconcile/Compensation/Rollback 대상으로 분리한다.
- Audit 에서 승인 Actor 와 업무 변경 Actor, Reason, Before/After, Operation 결과를 연결한다.

28. BZA 운영 인수 Gate

- 조직/직원/발령의 기준일·History 와 사용자·Role·Permission·Data Scope·Masking 의 실효 권한을 기준시각으로 판정한다.
- 조직 Tree 의 고아·순환·Version 충돌·중지 조직 포함 여부와 결재 Policy Version·상신/승인/반려/철회/취소·위임/대결·Owner 적용 결과를 분리해 추적한다.
- Attachment·Notification·Session·Audit·Export 의 권한·사유를 확인하고 Backup/Restore/Upgrade/Rollback 을 실제 환경에서 수행하지 않은 범위는 미검증으로 남긴다.
- EDU 개수가 아니라 제품 Source/API/UI/Test 와 고객 Public Integration 의 정합성으로 인수한다.

29. 현재 제품 검증 상태와 R6J 사용 경계

07_06 Final QA 중앙 Merge: 현재 master 는 07_05 제품 Source 위에 QA/Control 산출물을 추가한 Commit 이며 Product Source 변경은 없다. Final verdict 는 FAIL / REDEVELOPMENT REQUIRED + UNVERIFIED / RELEASE_BLOCKED 다. Canonical 완료 분모는 169 Requirement 이고, 신규 독립 개발 Action 은 31 개 (P0 22 / P1 9)다. 전체 Scope 는 169 Requirement + 기존 56 Finding + 신규 31 + self-found + Runtime 13 + 개발 중 추가 발견 전체이며, 34/34 direct rework 구현 사실만으로 완료 판정하지 않는다.

BZA Final QA: retired 410 API 가 active OpenAPI 200 operation 으로 노출되는 문제, 표준 401/403/404/409/422/429/500/503 계약 부족, Approval Simulation 의 명시적 SIMULATE permission/generated client 부재가 후속 재개발 대상이다.

- BZA 는 제품 Surface 이며 generic EDU 로 대체하지 않는다.
- 07_05 Source 에서 BZA Approval active consumer/permission projection 이 보완됐다. APPROVAL:WRITE/DECIDE 권한은 UI 와 요청 경계에서 확인하며, 실제 인증 Browser role matrix 는 미검증이다.
- 메뉴 권한만으로 제출/승인/Policy/Delegation mutation 을 허용하지 않는다. exact action grant 가 없으면 UI 와 API 모두 거부되어야 한다.
- 실제 인증 Session 의 browser role matrix 가 후속 exact SHA 에서 통과하기 전에는 운영 Release 승인 근거로 사용하지 않는다.